Software Architecture and Design Specification

Online Exam Portal

Prepared according to IEEE 42010 style structure

Field	Value
Project	Online Exam Portal
Document	Software Architecture and Design Specification (SAD)
Version	1.2
Date	05-10-2026
Status	Draft – Architecture & Design Complete
Authors	Chhavi Siddarth Wadhwa, Dhanya Prasad, Harsha K, Gagan
Architecture Owner (P3)	Harsha K
Design Owner (P4)	Gagan
Course	Software Engineering – Mini Project (Part 1)
Technology Stack	MERN (MongoDB, Express.js, React, Node.js)

Revision History

Version	Date	Author	Change Summary
1.0	03-10-2026	Harsha K (P3)	Initial Architecture section
1.1	04-10-2026	Harsha K (P3)	Aligned with official SRS v1.1, real Req IDs, MERN stack, updated Traceability & STRIDE
1.2	05-10-2026	Gagan (P4)	Added Section 4 Design: 3 UML sequence diagrams (UC-02, UC-09, UC-10), API design (catalogue + 4 detailed endpoints), error handling, logging & monitoring, UX design, design traceability, open issues

Approvals

Role	Name	Signature / Date
Project Manager / SRS (P1)	Chhavi Siddarth Wadhwa	
Test Plan (P2)	Dhanya Prasad	
Architecture (P3)	Harsha K	
Design (P4)	Gagan	
Instructor / Reviewer		

1. Introduction

1.1 Purpose

This document specifies the software architecture and high-level design of the Online Exam Portal. It describes the major components, architectural pattern, technology decisions, security architecture and traceability to the official Software Requirements Specification (SRS v1.1). It serves as the architectural baseline for implementation and for the Design section owned by P4.

1.2 Scope

The architecture covers the complete MERN-based Online Exam Portal: account management, question bank, exam creation and scheduling, timed exam attempts with auto-save and auto-submit, automatic evaluation, results, notifications, focus-loss logging and audit logging. Out of scope items (webcam proctoring, descriptive answers, native mobile apps) are excluded.

1.3 Audience

Developers, QA engineers (P2), Design owner (P4), instructors and reviewers.

1.4 Definitions

MERN – MongoDB, Express.js, React, Node.js; MCQ – Multiple Choice Question; JWT – JSON Web Token; RBAC – Role-Based Access Control; STRIDE – Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege; TLS – Transport Layer Security; SRS / STP / RTM – Software Requirements Specification / Software Test Plan / Requirements Traceability Matrix.

2. Document Overview

2.1 How to use this document

Section 3 defines the architecture (components, pattern, security, traceability). Section 4 contains the design (sequence diagrams, API design, error handling, logging & monitoring, UX design and design traceability) owned by P4. All requirement IDs used in this document are taken from the frozen SRS v1.1 and the ID Cheat Sheet.

2.2 Related Documents

SRS Online Exam Portal v1.1, Software Test Plan (STP), Requirements Traceability Matrix (RTM spreadsheet), ID Cheat Sheet.

3. Architecture

3.1 Goals & Constraints

Goals:

- Secure and reliable delivery of timed MCQ examinations with automatic evaluation.
- Support up to 500 concurrent students during exam windows while meeting response-time targets (NFR-OE-001 to NFR-OE-003).
- Enforce strong authentication, RBAC and exam integrity (SEC-OE series).
- Provide clear modular structure that maps cleanly to the MERN stack.

Constraints:

- Must use the MERN stack (MongoDB, Express.js, React, Node.js) as fixed in SRS v1.1.
- Academic mini-project timeline ending 07-10-2026.
- Browser-based only; no native mobile apps.
- Three primary roles: Student, Instructor, Administrator.

3.2 Stakeholders & Concerns

Stakeholder	Key Concerns
Students	Simple interface, fair evaluation, reliable timer and auto-save during exams
Instructors	Easy question/exam management, accurate results, focus-loss visibility
Administrators	User & role management, audit logs, system security
Development Team	Clear component boundaries, MERN alignment, maintainability

3.3 Component Diagram

The system follows a layered architecture mapped onto the MERN stack.

Logical Component Structure:

Presentation Layer (React)

↓ HTTPS / REST (JSON)

API Layer (Express.js Controllers / Routes)

↓

Business Services Layer (Node.js)

- Authentication & Authorization Service
- Exam Management Service

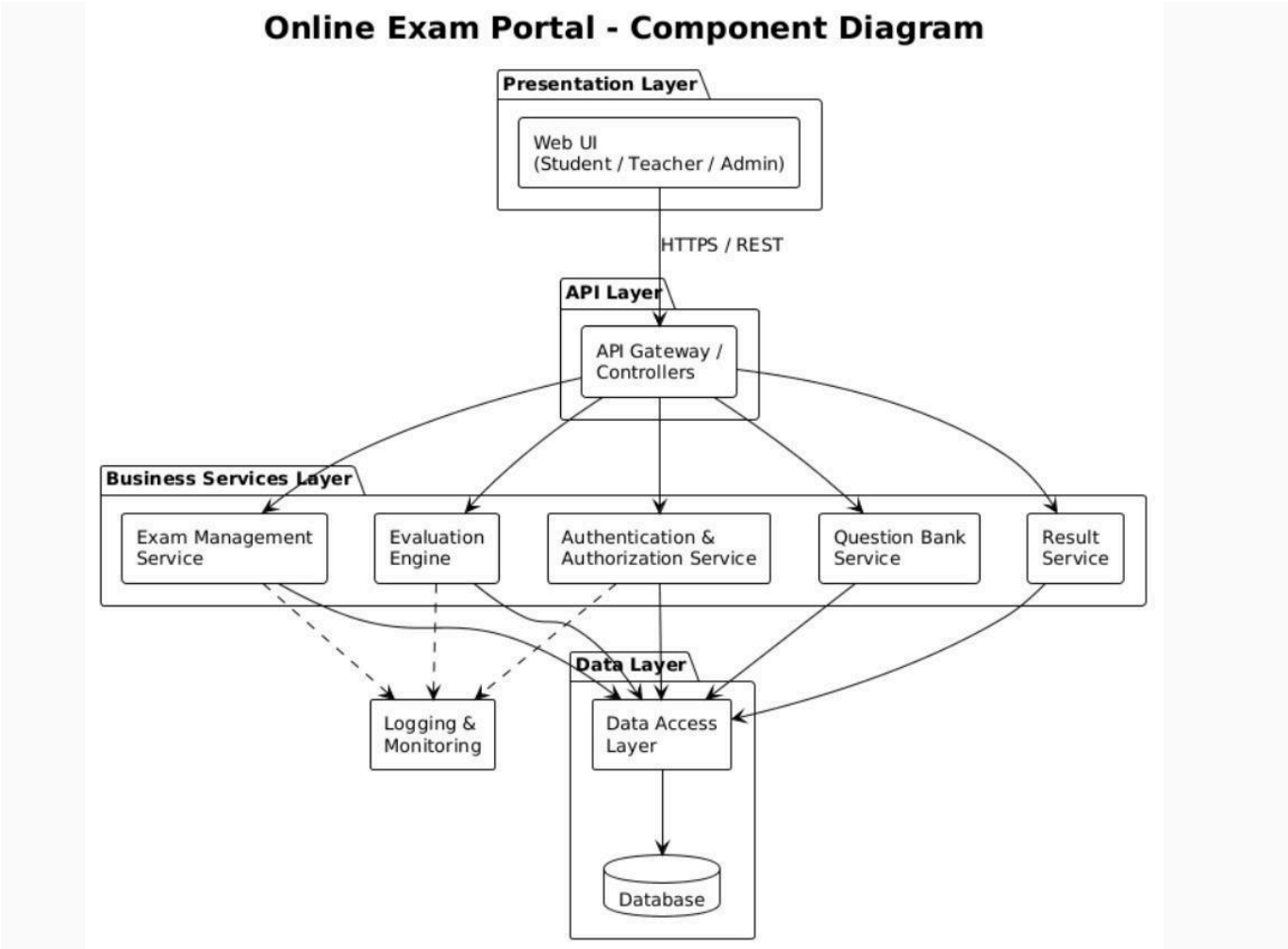
- Question Bank Service
- Evaluation Engine
- Result & Analytics Service
- Notification Service
- Audit & Logging Service

↓

Data Access Layer (Mongoose / MongoDB Drivers)

↓

MongoDB Database



3.4 Component Descriptions

Component	Responsibility
Presentation Layer (React)	Role-specific dashboards, exam-taking UI (timer, navigator, auto-save indicators), results views.
API Layer (Express Controllers)	REST endpoints, request validation, routing to services, JWT extraction.
Authentication & Authorization Service	Registration, login, password reset, JWT issuance/validation, RBAC enforcement (SEC-OE-001 to 006).
Exam Management Service	Create/configure/publish exams, assignment to students, start/resume/submit attempt logic, timer control, focus-loss recording.
Question Bank Service	CRUD for MCQs (2–6 options, single correct), ownership by Instructor.
Evaluation Engine	Auto-evaluation of submitted attempts, score calculation including negative marking.
Result & Analytics Service	Student result views, Instructor statistics (avg/high/low/pass %), CSV export.
Notification Service	In-app and email notifications for exam assignment and result availability (via SMTP).
Audit & Logging Service	Records login events, role changes, exam publication, submissions; supports filtering (FR-OE-027, SEC-OE-011).

Data Access Layer	Mongoose models and queries for all persistent entities.
MongoDB	Primary data store for Users, Questions, Exams, Attempts, Answers, FocusEvents, AuditLogs, Notifications.

3.5 Chosen Architecture Pattern and Rationale

Selected Pattern: Layered Architecture (mapped to MERN)

Rationale:

- Clear separation between React presentation, Express API, business services and MongoDB data store.
- Natural fit for the fixed MERN technology stack.
- Supports independent development of frontend and backend.
- Easy to reason about security boundaries (authZ checks in service layer).
- Microservices were rejected as unnecessary complexity for a mini-project with a four-person team.

3.6 Technology Stack & Data Stores

Layer	Technology
Frontend	React (latest stable)
Backend / API	Node.js + Express.js
Database	MongoDB (with Mongoose ODM)
Authentication	JWT (HttpOnly + Secure cookies or Authorization header) + bcrypt/Argon2
Email	SMTP service for verification, password reset and notifications
Communication	HTTPS + REST/JSON
Security	TLS 1.2+, input sanitisation, rate limiting, RBAC

3.7 Risks & Mitigations

Risk	Mitigation
High concurrent load during exams (NFR-OE-001–003)	Efficient MongoDB indexes, connection pooling, possible caching of questions
Cheating via tab switching	Focus-loss logging (FR-OE-021) visible to Instructor
Unauthorized access / privilege escalation	Server-side RBAC on every request (SEC-OE-004)
Timer manipulation	All timing decisions use server clock (NFR-OE-010)
Data loss on crash	Auto-save every 30 s + resume capability (FR-OE-017, FR-OE-018, NFR-OE-005)
Tight schedule	Modular services allow parallel work by P3/P4

3.8 Traceability to Requirements

Mapping of frozen Requirement IDs (from SRS v1.1 / ID Cheat Sheet) to Architecture Components. This column is what P3 must supply for the official RTM.

Req ID	Summary	Architecture Component(s)
FR-OE-001	Student registration	Authentication & Authorization Service
FR-OE-002	Email verification	Authentication & Authorization Service + Notification Service
FR-OE-003	Login + role-based access	Authentication & Authorization Service
FR-OE-004	Logout / session invalidation	Authentication & Authorization Service
FR-OE-005	Password reset	Authentication & Authorization Service + Notification Service
FR-OE-006	Admin user/role management	Authentication & Authorization Service
FR-OE-007	Question bank CRUD	Question Bank Service
FR-OE-008	Create exam	Exam Management Service
FR-OE-009	Question/option shuffling	Exam Management Service
FR-OE-010	Negative marking config	Exam Management Service + Evaluation Engine
FR-OE-011	Publish & assign exam	Exam Management Service + Notification Service
FR-OE-012	Lock exam after first attempt	Exam Management Service
FR-OE-013	List assigned exams + status	Exam Management Service
FR-OE-014	Start exam (window + once)	Exam Management Service
FR-OE-015	Answer, navigate, flag	Exam Management Service + Presentation Layer
FR-OE-016	Server-side countdown timer	Exam Management Service
FR-OE-017	Auto-save every 30 s	Exam Management Service
FR-OE-018	Resume interrupted attempt	Exam Management Service
FR-OE-019	Manual submit + confirmation	Exam Management Service
FR-OE-020	Auto-submit at timer zero	Exam Management Service

FR-OE-021	Focus-loss / tab-switch logging	Exam Management Service + Audit & Logging Service
FR-OE-022	Automatic evaluation & scoring	Evaluation Engine
FR-OE-023	Student view own result	Result & Analytics Service
FR-OE-024	Instructor statistics	Result & Analytics Service
FR-OE-025	CSV export of results	Result & Analytics Service
FR-OE-026	Notifications (assign + result)	Notification Service
FR-OE-027	Audit log viewing	Audit & Logging Service
NFR-OE-001	Page response ≤ 2 s (500 users)	All layers (esp. API + MongoDB)
NFR-OE-002	Auto-save ≤ 1 s	Exam Management Service + Data Access
NFR-OE-003	Evaluation ≤ 5 s	Evaluation Engine
NFR-OE-004	99.5 % availability in exam windows	Deployment + Monitoring
NFR-OE-005	RPO ≤ 30 s (auto-save)	Exam Management Service
NFR-OE-010	Server clock for all timing	Exam Management Service
SEC-OE-001	Password hashing (bcrypt/Argon2)	Authentication & Authorization Service
SEC-OE-002	Password complexity	Authentication & Authorization Service
SEC-OE-003	Account lockout after 5 failures	Authentication & Authorization Service
SEC-OE-004	Server-side RBAC (HTTP 403)	Authentication & Authorization Service
SEC-OE-005	HTTPS / TLS 1.2+	API Layer + Infrastructure
SEC-OE-006	Session expiry + HttpOnly/Secure	Authentication & Authorization Service
SEC-OE-007	Correct answers never sent early	Exam Management + Evaluation Engine
SEC-OE-008	Input validation, NoSQL injection, XSS, CSRF	API Layer + All Services
SEC-OE-009	Submission only by owner before end+5s	Exam Management Service
SEC-OE-010	Rate limiting (login/reset)	API Layer
SEC-OE-011	Security event logging (12 months)	Audit & Logging Service
SEC-OE-012	Encryption of personal data at rest	Data Access Layer + MongoDB

3.9 Security Architecture

Threat modelling uses STRIDE. Each threat is linked to the official Security Requirements (SEC-OE-xxx) from the SRS.

Threat	Related SEC-OE	Architectural Mitigation	Primary Component
Spoofing	SEC-OE-001, 002, 003, 006	Salted password hashes, complexity rules, lockout, JWT with expiry + HttpOnly/Secure	Authentication & Authorization Service
Tampering	SEC-OE-008, 009	Input sanitisation, NoSQL injection protection, owner-only submission before deadline	API Layer + Exam Management Service
Repudiation	SEC-OE-011	Immutable audit log of login, role changes, publication, submissions	Audit & Logging Service
Information Disclosure	SEC-OE-005, 007, 012	TLS 1.2+, correct answers withheld until release, encryption at rest	API Layer + Evaluation Engine
Denial of Service	SEC-OE-010 + NFR-OE-001/004	Rate limiting on auth endpoints, efficient queries, availability target	API Layer
Elevation of Privilege	SEC-OE-004	RBAC enforced on every server request; UI checks are not trusted	Authentication & Authorization Service

Key Security Decisions:

- All authentication and authorisation decisions are made on the server (never trust the React client).
- Exam timers, start/end windows and auto-submit are driven exclusively by the server clock.
- Correct answers are never included in any API response until the attempt is submitted and results are released (SEC-OE-007).
- Focus-loss events are recorded server-side and made visible only to the Instructor.

4. Design

4.1 Design Overview

The design realises the layered MERN architecture of Section 3. Each architecture component is implemented as a backend module with the same internal layering: Express route -> middleware chain -> controller -> service -> Mongoose model. The React client is a single-page application with one route tree per role. This section is owned

by P4 (Gagan) and covers the sequence diagrams, REST API contracts, error handling, logging and monitoring, and UX notes.

Design principles:

- Server is the source of truth: authentication, RBAC, exam windows, timer end time and scoring are decided only on the server (SEC-OE-004, NFR-OE-010).
- Thin controllers, fat services: controllers only parse/validate the request and shape the response; all business rules live in services so they can be unit-tested (NFR-OE-012).
- Idempotent exam operations: start, auto-save and submit can be safely retried by the client without creating duplicate attempts or double scoring (NFR-OE-005).
- Least data to the client: question payloads are built with a projection that never includes the correct option (SEC-OE-007).
- Every security-relevant action passes through the Audit & Logging Service (SEC-OE-011).

Module structure (backend, Node.js + Express):

Module / folder	Contents	Architecture component (Section 3.4)
routes/	auth.routes, user.routes, question.routes, exam.routes, attempt.routes, result.routes, audit.routes	API Layer
middleware/	authenticate (JWT + session), authorize(role), validate(schema), rateLimit, csrf, requestId, errorHandler	API Layer + Auth & Authorization Service
services/auth	register, verifyEmail, login, logout, resetPassword, lockout logic	Authentication & Authorization Service
services/question	MCQ CRUD, option-count and single-correct validation	Question Bank Service
services/exam	exam CRUD, publish/assign, lock after first attempt, start/resume/save/submit attempt, focus events	Exam Management Service
services/evaluation	evaluate(attemptId), score and pass/fail computation	Evaluation Engine
services/result	student result view, instructor statistics, CSV export	Result & Analytics Service
services/notification	in-app notifications, SMTP email (Nodemailer)	Notification Service
services/audit	append-only audit writer and filtered reader	Audit & Logging Service
jobs/	autoSubmit.job (every 10 s), backup.job (daily)	Exam Management Service, Deployment
models/	Mongoose schemas listed below	Data Access Layer

Key data entities (MongoDB collections):

Collection	Key fields	Indexes / notes
users	_id, name*, email*, passwordHash, role, status, emailVerified, failedLogins, lockedUntil	unique email; * encrypted at rest (SEC-OE-012)
sessions	sid, userId, role, lastActivity, expiresAt	TTL index on expiresAt (30-min inactivity, SEC-OE-006)
questions	_id, ownerId, text, options[2..6], correctOption, marks	ownerId; correctOption excluded from student projections
exams	_id, title, durationMin, startAt, endAt, passMark, questionIds[], shuffle, negativeMark, status, locked, resultsReleased	status + startAt
assignments	examId, studentId, assignedAt	unique (examId, studentId)

Collection	Key fields	Indexes / notes
attempts	_id, examId, studentId, startedAt, endsAt, status (IN_PROGRESS / SUBMITTED), submitMode, lastSeq, score, passed	unique (examId, studentId) enforces "only once"; (status, endsAt) for auto-submit job
answers	attemptId, questionId, selectedOption, flagged, savedAt	unique (attemptId, questionId)
focusEvents	attemptId, type (BLUR / HIDDEN), serverTimestamp	attemptId
notifications	userId, type, message, read, createdAt	userId + read
auditLogs	action, userId, ip, timestamp, details	append-only; timestamp; retained >= 12 months (SEC-OE-011)

4.2 UML Sequence Diagrams

Three sequence diagrams cover the flows assigned to P4 in the ID Cheat Sheet: UC-02 Login / Logout, UC-09 Attempt Exam and UC-10 Submit Exam. Lifelines use the component names from Section 3.4 so that each message can be traced to an architecture component. Diagram sources (Mermaid) are stored in the repository under Design/diagrams/.

4.2.1 SD-01: Login / Logout (UC-02)

Requirements covered: FR-OE-003, FR-OE-004, SEC-OE-001, SEC-OE-003, SEC-OE-004, SEC-OE-006, SEC-OE-008, SEC-OE-010, SEC-OE-011.

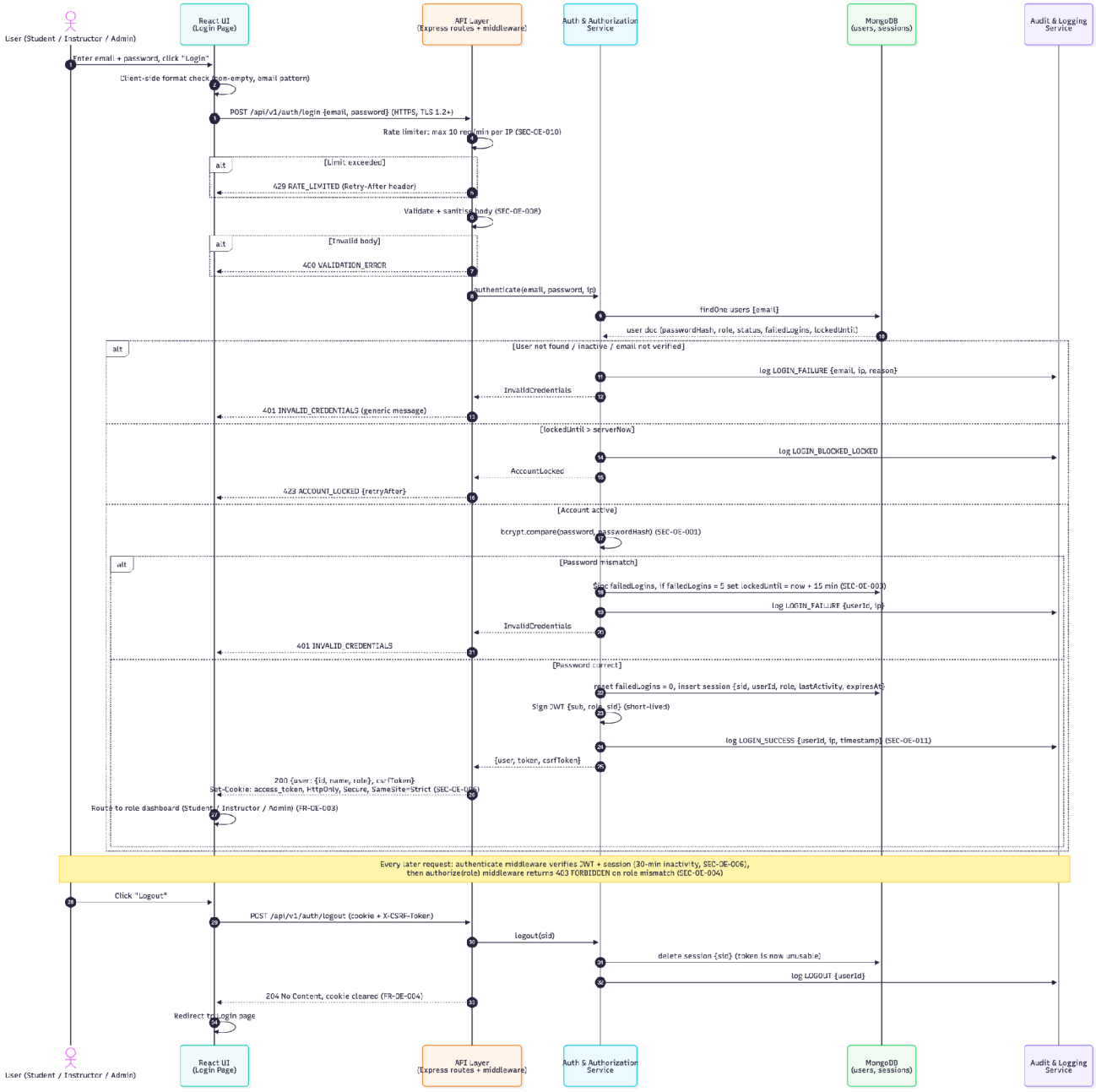


Figure 4.1 - SD-01 Login / Logout sequence diagram

Key design points:

- The rate limiter runs before any database access so brute-force traffic is rejected cheaply with HTTP 429 (SEC-OE-010).
- Unknown email, wrong password and unverified account all return the same generic 401 message to prevent account enumeration.
- The 5th consecutive failure sets lockedUntil = now + 15 min; while locked, login returns 423 without checking the password (SEC-OE-003).
- The JWT is delivered only in an HttpOnly, Secure, SameSite=Strict cookie and is bound to a server-side session (sid), so logout and inactivity expiry invalidate it immediately (FR-OE-004, SEC-OE-006).

4.2.2 SD-02: Attempt Exam (UC-09)

Requirements covered: FR-OE-012 to FR-OE-018, FR-OE-021, NFR-OE-002, NFR-OE-010, SEC-OE-004, SEC-OE-007, SEC-OE-009.

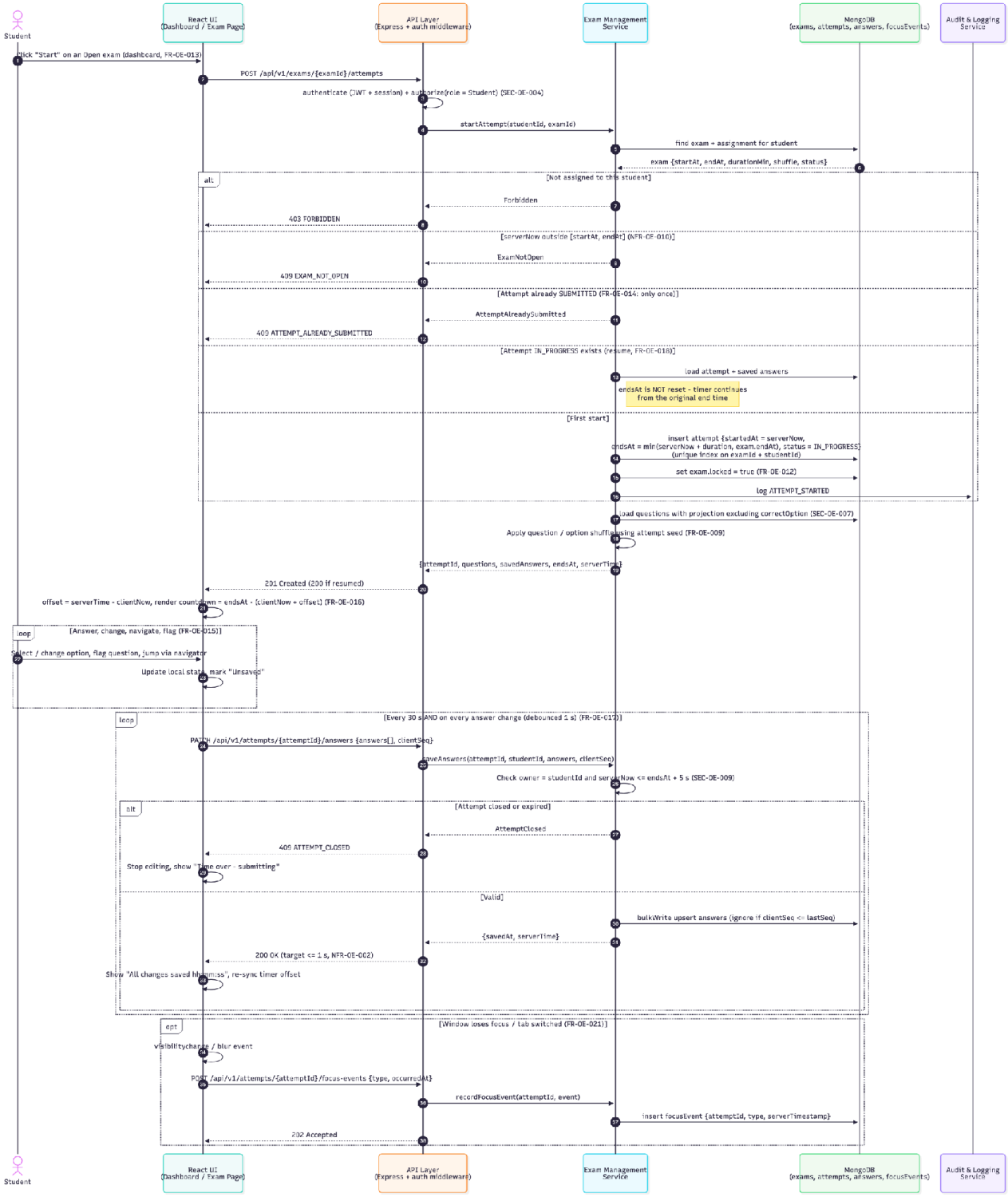


Figure 4.2 - SD-02 Attempt Exam sequence diagram

Key design points:

- endsAt is computed once on the server at first start as min(startedAt + duration, exam.endAt) and is never reset on resume (FR-OE-016, FR-OE-018).
- The client never trusts its own clock: it computes an offset from serverTime in every response and re-syncs on every auto-save, keeping deviation within 2 s (NFR-OE-010).
- A unique index on (examId, studentId) in attempts guarantees a single attempt even under concurrent "Start" clicks (FR-OE-014).

- Auto-save sends only changed answers with a monotonically increasing clientSeq; stale or out-of-order saves are ignored (FR-OE-017, NFR-OE-005).
- Focus-loss events are fire-and-forget (202 Accepted) so they never block answering (FR-OE-021).

4.2.3 SD-03: Submit Exam (UC-10)

Requirements covered: FR-OE-019, FR-OE-020, FR-OE-022, FR-OE-023, FR-OE-026, NFR-OE-003, NFR-OE-005, SEC-OE-009, SEC-OE-011.

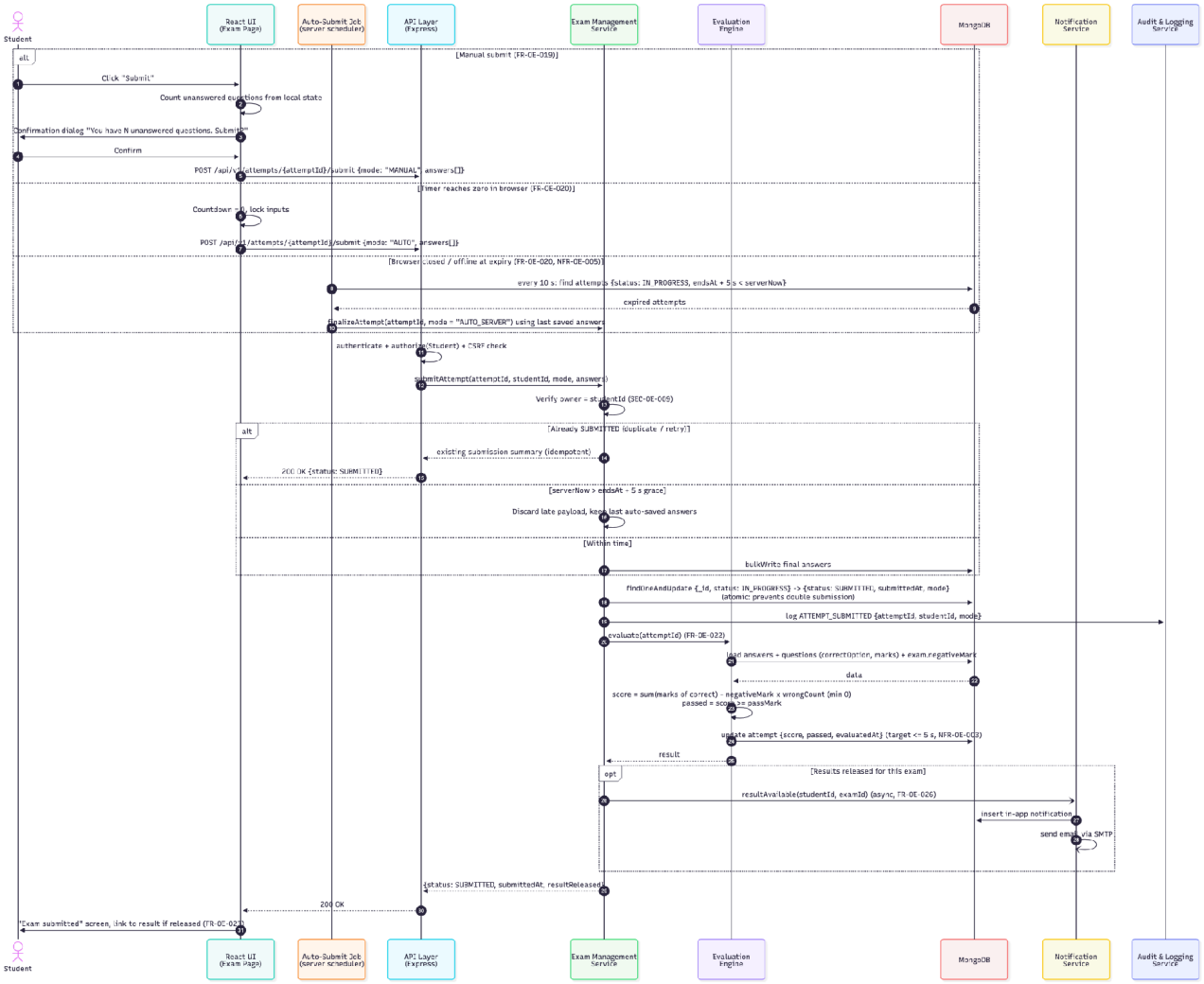


Figure 4.3 - SD-03 Submit Exam sequence diagram

Key design points:

- Three entry points converge on one submitAttempt() service: manual submit, client auto-submit at 00:00, and the server Auto-Submit Job for students who closed the browser (FR-OE-019, FR-OE-020).
- The status change IN_PROGRESS -> SUBMITTED is a single conditional findOneAndUpdate, so duplicate requests cannot double-submit or double-score; repeats return the existing summary.
- Payloads arriving after endsAt + 5 s are discarded and the last auto-saved answers are used (SEC-OE-009).
- Evaluation runs synchronously inside the submit request (MCQ scoring is O(number of questions)), keeping score availability under 5 s (NFR-OE-003). Notifications are sent asynchronously so SMTP latency never delays the response.

4.3 API Design

4.3.1 Conventions

- Base URL: https://<host>/api/v1 - HTTPS only, plain HTTP is redirected/rejected (SEC-OE-005).

- Format: JSON (Content-Type: application/json); timestamps in ISO 8601 UTC; IDs are MongoDB ObjectId strings.
- Authentication: access_token cookie (HttpOnly, Secure, SameSite=Strict). State-changing requests also send the X-CSRF-Token header (SEC-OE-008).
- Authorisation: every route declares its allowed roles; the authorize middleware returns 403 FORBIDDEN otherwise (SEC-OE-004).
- Validation: every request body/query is validated against a schema (Joi / express-validator) and sanitised (express-mongo-sanitize) before reaching a controller (SEC-OE-008).
- Errors: all errors use the standard envelope defined in Section 4.4. Every response carries an X-Request-Id header for log correlation.

4.3.2 Endpoint Catalogue

API ID	Method & Path	Role	Purpose	Req IDs
API-01	POST /auth/register	Public	Register Student account	FR-OE-001, SEC-OE-002
API-02	GET /auth/verify-email?token=	Public	Verify email (24 h link)	FR-OE-002
API-03	POST /auth/login	Public	Authenticate, start session	FR-OE-003, SEC-OE-001/003/006/010
API-04	POST /auth/logout	Any	End session	FR-OE-004
API-05	POST /auth/password-reset/request	Public	Email one-time reset link	FR-OE-005, SEC-OE-010
API-06	POST /auth/password-reset/confirm	Public	Set new password (30 min link)	FR-OE-005, SEC-OE-002
API-07	GET | POST | PATCH /users[/:id]	Admin	Manage users and roles	FR-OE-006, NFR-OE-014*
API-08	GET | POST | PUT | DELETE /questions[/:id]	Instructor	Question bank CRUD	FR-OE-007
API-09	POST | PUT /exams[/:id]	Instructor	Create / configure exam (409 EXAM_LOCKED after first attempt)	FR-OE-008, 009, 010, 012
API-10	POST /exams/:examId/publish	Instructor	Publish and assign to students	FR-OE-011, FR-OE-026
API-11	GET /me/exams	Student	List assigned exams with status	FR-OE-013
API-12	POST /exams/:examId/attempts	Student	Start or resume attempt	FR-OE-014, 016, 018, SEC-OE-007
API-13	PATCH /attempts/:attemptId/answers	Student	Auto-save answers	FR-OE-015, FR-OE-017, NFR-OE-002
API-14	POST /attempts/:attemptId/focus-events	Student	Record focus loss	FR-OE-021
API-15	POST /attempts/:attemptId/submit	Student	Manual / auto submit + evaluate	FR-OE-019, 020, 022
API-16	GET /attempts/:attemptId/result	Student	Own score and review	FR-OE-023, SEC-OE-007
API-17	GET /exams/:examId/results	Instructor	Attempts, statistics, focus-loss counts	FR-OE-024, FR-OE-021

API ID	Method & Path	Role	Purpose	Req IDs
API-18	GET /exams/:examId/results/export	Instructor	CSV download	FR-OE-025
API-19	GET /notifications	Any	In-app notifications	FR-OE-026
API-20	GET /audit-logs?from&to&userId	Admin	Filtered audit log	FR-OE-027, SEC-OE-011
API-21	GET /health	Public	Liveness / DB readiness probe	NFR-OE-004

** API-07 also covers the Administrator deleting data of a deactivated user (NFR-OE-014).*

4.3.3 Detailed Endpoint Specifications

The four endpoints below are fully specified because they implement the critical exam and login flows (FR-OE-003, FR-OE-017, FR-OE-019, FR-OE-020) and are the primary targets for API test cases in the Test Plan (P2).

API-03 POST /api/v1/auth/login

Component	Authentication & Authorization Service
Requirements	FR-OE-003, SEC-OE-001, SEC-OE-003, SEC-OE-006, SEC-OE-008, SEC-OE-010, SEC-OE-011
Auth	None (public). Rate limited: 10 requests / minute / IP.

Request body	`{`
	`  "email": "student1@pes.edu",  // required, valid email, max 254`
	`  "password": "Secret123"  // required, 8-128 chars`
	`}`

Success 200	`{`
	`  "user": { "id": "66f1...a2", "name": "Asha R", "role": "STUDENT" },`
	`  "csrfToken": "b9c1...",`
	`  "sessionExpiresInSec": 1800`
	`}`
	`Set-Cookie: access_token=<JWT>; HttpOnly; Secure; SameSite=Strict; Path=/`

Errors	400 VALIDATION_ERROR - missing/malformed field 401 INVALID_CREDENTIALS - wrong email/password or unverified account (generic) 423 ACCOUNT_LOCKED - 5 failed attempts, details.retryAfterSec 429 RATE_LIMITED - more than 10 req/min from this IP
Side effects	Resets or increments failedLogins; creates session; writes LOGIN_SUCCESS / LOGIN_FAILURE audit entry with userId, IP, timestamp.

API-12 POST /api/v1/exams/{examId}/attempts

Component	Exam Management Service
Requirements	FR-OE-012, FR-OE-014, FR-OE-016, FR-OE-018, NFR-OE-010, SEC-OE-004, SEC-OE-007
Auth	Cookie + X-CSRF-Token. Role: STUDENT; student must be assigned to examId.
Request body	`(empty)`

Success 201 / 200	`201 = new attempt, 200 = resumed attempt`
	`{`
	`  "attemptId": "6700...9c",`
	`  "status": "IN_PROGRESS",`
	`  "startedAt": "2026-10-10T04:30:02Z",`
	`  "endsAt": "2026-10-10T05:30:02Z",`
	`  "serverTime": "2026-10-10T04:30:02Z",`

	<pre>"questions": [{ "questionId": "q1", "text": "...", "marks": 2, "options": [{"id": "a", "text": "..."}, {"id": "b", "text": "..."}] }], // never contains correctOption "savedAnswers": [{ "questionId": "q1", "selectedOption": "b", "flagged": false }] }</pre>
Errors	401 UNAUTHENTICATED - no/expired session 403 FORBIDDEN - not a Student or not assigned 404 NOT_FOUND - examId does not exist 409 EXAM_NOT_OPEN - server time outside start/end window 409 ATTEMPT_ALREADY_SUBMITTED - attempt already used
Side effects	First start: inserts attempt, sets exam.locked = true, audit ATTEMPT_STARTED.

API-13 PATCH /api/v1/attempts/{attemptId}/answers (auto-save)

Component	Exam Management Service
Requirements	FR-OE-015, FR-OE-017, NFR-OE-002, NFR-OE-005, SEC-OE-009
Auth	Cookie + X-CSRF-Token. Role: STUDENT and owner of the attempt.
Trigger	Every 30 s and on every answer change (debounced 1 s).
Request body	<pre>{ "clientSeq": 42, // increasing per attempt "answers": [{ "questionId": "q1", "selectedOption": "c", "flagged": false }, { "questionId": "q7", "selectedOption": null, "flagged": true }] // only changed answers, max 200 }</pre>
Success 200	<pre>{ "savedAt": "2026-10-10T04:41:30Z", "serverTime": "2026-10-10T04:41:30Z", "savedCount": 2 }</pre>
Errors	400 VALIDATION_ERROR - unknown questionId / optionId 403 FORBIDDEN - not the owner 409 ATTEMPT_CLOSED - attempt SUBMITTED or serverTime > endsAt + 5 s 429 RATE_LIMITED - more than 30 saves/min for this attempt
Performance	p95 <= 1 s at 500 concurrent users (NFR-OE-002): single bulkWrite on the indexed answers collection.

API-15 POST /api/v1/attempts/{attemptId}/submit

Component	Exam Management Service -> Evaluation Engine
Requirements	FR-OE-019, FR-OE-020, FR-OE-022, NFR-OE-003, SEC-OE-009, SEC-OE-011
Auth	Cookie + X-CSRF-Token. Role: STUDENT and owner. (Server Auto-Submit Job calls the same service directly.)
Request body	<pre>{ "mode": "MANUAL", // MANUAL | AUTO "clientSeq": 57, "answers": [{ "questionId": "q3", "selectedOption": "a", "flagged": false }] }</pre>
Success 200	<pre>{ "attemptId": "6700...9c", "status": "SUBMITTED", "submitMode": "MANUAL", "submittedAt": "2026-10-10T05:12:44Z", "resultReleased": true,</pre>

	`"score": 34, "maxScore": 40, "passed": true // only if resultReleased` `}`
Errors	401 UNAUTHENTICATED 403 FORBIDDEN - not the owner 404 NOT_FOUND - attemptId does not exist Note: a repeated submit returns 200 with the existing summary (idempotent); a late submit (> endsAt + 5 s) is accepted but its answers are ignored.
Side effects	Attempt status -> SUBMITTED, score computed, audit ATTEMPT_SUBMITTED, result notification queued if released.

4.4 Error Handling, Logging & Monitoring

4.4.1 Error Handling Strategy

- Services throw typed AppError objects (code, httpStatus, message, details). A single Express errorHandler middleware converts them into the standard envelope; unknown errors become 500 INTERNAL_ERROR with no stack trace in the response.
- Validation errors are returned with field-level details so the React forms can highlight the exact field.
- Authentication failures use generic messages (no hint whether the email exists).
- Async route handlers are wrapped so that rejected promises always reach the errorHandler; process-level unhandledRejection is logged and the process is restarted by PM2 / Docker.

Standard error envelope:

```
{
  "error": {
    "code": "ATTEMPT_CLOSED",
    "message": "This attempt has ended and can no longer be changed.",
    "details": { "endsAt": "2026-10-10T05:30:02Z" },
    "requestId": "c0a8-4f1e-91d2"
  }
}
```

Error code catalogue:

HTTP	Code	Raised when	Client (React) behaviour
400	VALIDATION_ERROR	Body/query fails schema validation	Show inline field errors
401	INVALID_CREDENTIALS	Login with wrong email/password	Generic "Email or password is incorrect"
401	UNAUTHENTICATED	Missing / expired session (30 min idle)	Redirect to login; resume attempt after re-login (FR-OE-018)
403	FORBIDDEN	Role or ownership check fails (SEC-OE-004)	Show "Not permitted" page
403	CSRF_INVALID	Missing / wrong X-CSRF-Token	Refresh token and retry once
404	NOT_FOUND	Resource id does not exist	Show not-found message
409	EXAM_NOT_OPEN	Start outside exam window	Show window times
409	ATTEMPT_ALREADY_SUBMITTED	Second start of same exam	Go to result / status page
409	ATTEMPT_CLOSED	Save after submit or after endsAt + 5 s	Lock UI, show "Submitted" screen
409	EXAM_LOCKED	Editing exam after first attempt (FR-OE-012)	Disable edit form, show reason
423	ACCOUNT_LOCKED	5 consecutive failed logins (SEC-OE-003)	Show unlock time

HTTP	Code	Raised when	Client (React) behaviour
429	RATE_LIMITED	Rate limit exceeded (SEC-OE-010)	Wait Retry-After seconds
500	INTERNAL_ERROR	Unexpected server error	Generic message with requestId
503	SERVICE_UNAVAILABLE	Database unreachable / maintenance	Retry with back-off

Exam-page resilience (NFR-OE-005): if an auto-save fails with a network error or 5xx, the React client keeps the unsaved answers in a local queue (memory + localStorage), retries with exponential back-off (1, 2, 4, 8, max 15 s) and shows an "Offline - answers will be saved when connection returns" banner. Because the server saves at least every 30 s, at most 30 s of answers can be lost in a server failure.

4.4.2 Logging

Log type	Content	Storage & retention
Application log	Structured JSON (pino/winston): timestamp, level, requestId, userId, route, status, latencyMs	stdout -> file / log service, 30 days
Audit log	LOGIN_SUCCESS / FAILURE, LOGOUT, ROLE_CHANGED, EXAM_CREATED, EXAM_PUBLISHED, ATTEMPT_STARTED, ATTEMPT_SUBMITTED, RESULT_VIEWED with userId, IP, timestamp	auditLogs collection, append-only, >= 12 months (SEC-OE-011, FR-OE-027)
Security events	Lockouts, 403s, 429s, CSRF failures	Application log at WARN level + audit log

- Never logged: passwords, password hashes, JWT / session / CSRF tokens, reset and verification tokens, correct options, full request bodies of auth routes (SEC-OE-001, SEC-OE-007). A redaction list is configured in the logger.
- Levels: ERROR (5xx, job failures), WARN (security events, retries), INFO (one line per request), DEBUG disabled in production.
- Every log line carries the requestId so a client error report can be traced end to end.

4.4.3 Monitoring & Alerting

ID	Metric	Target	Alert when	Req ID
M-01	p95 API / page response time	<= 2 s	> 1.5 s for 5 min	NFR-OE-001
M-02	p95 auto-save latency (API-13)	<= 1 s	> 0.8 s for 5 min	NFR-OE-002
M-03	Submit-to-score time	<= 5 s	any > 5 s	NFR-OE-003
M-04	Uptime of GET /health (1-min external ping)	>= 99.5 % in exam windows	2 consecutive failures	NFR-OE-004
M-05	5xx error rate	< 1 %	> 1 % for 5 min	NFR-OE-004
M-06	Expired attempts still IN_PROGRESS	0	> 0 for 30 s (auto-submit job stalled)	FR-OE-020
M-07	Failed logins / 429s per minute	baseline	> 5x baseline	SEC-OE-003, SEC-OE-010
M-08	Daily backup job result	success	failure or missing	NFR-OE-006

Implementation: prom-client exposes metrics from Express; Grafana dashboards display them; an external uptime monitor pings /health. Alerts go to the team by email.

4.5 UX Design

The UX goal is a calm, distraction-free exam experience that works for first-time users without training (NFR-OE-007).

Screen / element	Design decision	Req ID
Student dashboard	Exam cards grouped by status chip (Upcoming, Open, Attempted, Missed). The "Start" button is on the card: Dashboard -> Start -> Confirm instructions = 3 clicks.	FR-OE-013, NFR-OE-007
Exam page header	Exam title, countdown timer (hh:mm:ss) and save status ("All changes saved 10:41:30" / "Saving..." / "Offline").	FR-OE-016, FR-OE-017
Timer	Turns amber at 5 min and red at 1 min; screen-reader announcements at 5 and 1 min via aria-live. At 00:00 inputs lock and auto-submit runs.	FR-OE-016, FR-OE-020
Question panel	One question at a time; options are native radio buttons; Previous / Next / Flag for review buttons.	FR-OE-015
Question navigator	Grid of numbered buttons showing answered, unanswered and flagged state with icon + colour (never colour only). Collapses to a drawer below 768 px.	FR-OE-015, NFR-OE-008, NFR-OE-009
Submit dialog	Modal shows "N unanswered, M flagged" with Go back / Submit; focus is trapped in the modal.	FR-OE-019
Focus-loss notice	Student sees a short notice at exam start that tab switches are recorded.	FR-OE-021
Result page	Score, pass/fail badge, and question-wise review only if enabled by the Instructor.	FR-OE-023
Instructor results	Attempts table with score, submit mode and focus-loss count; statistics cards; "Export CSV" button.	FR-OE-024, FR-OE-025, FR-OE-021
Errors & forms	Plain-language messages, inline field errors, no stack traces or internal codes shown to users.	Section 4.4

Accessibility and compatibility:

- WCAG 2.1 AA on exam pages: text contrast >= 4.5:1, visible focus ring, all actions reachable by keyboard (Tab order, 1-6 to choose option, N / P for next / previous, F to flag) (NFR-OE-008).
- Responsive layout from 360 px width; tested on the latest two versions of Chrome, Firefox and Edge (NFR-OE-009).
- Minimum 16 px body text, large tap targets (44 x 44 px) for options on mobile.

4.6 Design Traceability to Requirements

Design references for the "Design / API ref - P4" column of the RTM. SD = sequence diagram (4.2), API = endpoint (4.3), M = monitoring metric (4.4.3).

Req ID	Design reference
FR-OE-001, FR-OE-002	API-01, API-02; services/auth
FR-OE-003	SD-01; API-03
FR-OE-004	SD-01; API-04
FR-OE-005	API-05, API-06
FR-OE-006	API-07
FR-OE-007	API-08; questions collection
FR-OE-008, 009, 010	API-09; exams collection

Req ID	Design reference
FR-OE-011	API-10
FR-OE-012	SD-02 (exam.locked); API-09 (409 EXAM_LOCKED)
FR-OE-013	API-11; 4.5 Student dashboard
FR-OE-014, 016, 018	SD-02; API-12
FR-OE-015, 017	SD-02; API-13; 4.5 Question panel / navigator
FR-OE-019, 020	SD-03; API-15; jobs/autoSubmit; M-06
FR-OE-021	SD-02; API-14; API-17
FR-OE-022	SD-03; services/evaluation
FR-OE-023	API-16; 4.5 Result page
FR-OE-024, 025	API-17, API-18
FR-OE-026	SD-03; API-10; API-19
FR-OE-027	API-20; 4.4.2 Audit log
NFR-OE-001 to 004	M-01 to M-05; API-21
NFR-OE-005	SD-02, SD-03; 4.4.1 exam-page resilience
NFR-OE-006	jobs/backup; M-08
NFR-OE-007 to 009	4.5 UX Design
NFR-OE-010	SD-02 (serverTime offset); API-12
NFR-OE-011	4.1 indexes
NFR-OE-012	4.1 module structure (services unit-testable)
NFR-OE-013	4.7 next steps (Docker Compose)
NFR-OE-014	API-07; 4.1 data entities
SEC-OE-001 to 004, 006, 010	SD-01; API-03
SEC-OE-005, 008	4.3.1 conventions
SEC-OE-007	SD-02; API-12, API-16
SEC-OE-009	SD-02, SD-03; API-13, API-15
SEC-OE-011	4.4.2 Logging; API-20
SEC-OE-012	4.1 data entities (encrypted fields)

4.7 Open Issues & Next Steps

#	Item	Type	Owner
1	Confirm whether results are released immediately or manually by the Instructor (affects SD-03 notification and API-15 response).	Open issue	P1 / P4
2	Choose token transport for mobile-width clients: cookie only (current design) vs. Authorization header.	Open issue	P3 / P4
3	Map API-03, API-12, API-13, API-15 error codes to TC-OE test cases in the Test Plan.	Next step	P2 / P4
4	Publish an OpenAPI 3.0 (Swagger) file generated from the endpoint specs in 4.3.	Next step	P4
5	Docker Compose file (React, Node, MongoDB) with a	Next step	P3 / P4

#	Item	Type	Owner
	one-page setup guide (NFR-OE-013).		
6	Load-test auto-save and submit with JMeter / k6 at 500 virtual users (NFR-OE-001 to 003).	Next step	P2
7	Future enhancements: webcam proctoring, descriptive answers, randomised question pools.	Future	-

5. Appendices

5.1 Glossary

MERN, MCQ, JWT, RBAC, STRIDE, TLS, SRS, STP, RTM, API, UI, ODM; CSRF – Cross-Site Request Forgery; TTL – Time-To-Live index; p95 – 95th-percentile latency; SD – Sequence Diagram; WCAG – Web Content Accessibility Guidelines.

5.2 References

IEEE 42010, IEEE 1016 (Software Design Descriptions), OWASP Top 10, OWASP ASVS, NIST SP 800-160, RFC 9110 (HTTP Semantics), WCAG 2.1, Official SRS v1.1, ID Cheat Sheet, RTM spreadsheet.

5.3 Tools

draw.io / diagrams.net, Mermaid (sequence diagrams), PlantUML, Postman / Swagger (OpenAPI 3.0), MongoDB Compass, Git.